Fuerza bruta y bloqueo de cuentas

Propuesta de Trabajo Práctico — Seguridad en el desarrollo de software

Qué es la fuerza bruta

Es un método de ataque que consiste en probar sistemáticamente muchas combinaciones (usuarios, contraseñas) hasta encontrar una que funcione, esto puede hacerse con un "stock" de contraseñas posibles e ir intentando una por una. No explota ninguna falla de programación: ataca directamente el mecanismo de autenticación, aprovechando que no hay nada que lo frene. Si el sistema no esta pensado con esta vulnerabilidad en mente el atacante puede intentar diferentes combinaciones sin descanso, encontrando tarde o temprano la contraseña que le permita entrar.

De que trata el proyecto

Construimos un mismo sistema de login en 5 niveles de seguridad creciente, para mostrar que tener una contraseña no alcanza: lo que de verdad frena la fuerza bruta es cómo se detecta y bloquea el abuso de intentos.

Nivel	Criterio de bloqueo	Qué demuestra
Nivel 1	Sin bloqueo	Nunca bloquea. Representa un sistema sin ningún control frente a la fuerza bruta.
Nivel 2	Usuario	Bloquea a los 3 intentos fallidos en 5 minutos. Es un bloqueo global por cuenta: frena la fuerza bruta clásica, pero un atacante puede dejar sin acceso a su cuenta a un usuario real solo conociendo su nombre de usuario.
Nivel 3	Usuario + IP	Mismo límite, pero distingue por IP. El usuario legítimo no se ve afectado si el ataque viene de otro lugar, pero le da la posibilidad al atacante de evadir el bloqueo cambiando de IP. Además de tener el mismo problema del nivel 2 si el usuario y el atacante están bajo la misma IP.
Nivel 4	Usuario + IP + User Agent	Agrega el navegador/dispositivo como criterio. Aunque el atacante y el usuario legitimo estuvieran bajo la misma IP, al también usar el User Agent como criterio el usuario legitimo podría ingresar a su cuenta. Pero también le da otra herramienta para sobrepasar la protección al atacante, puede intentar cambiar su User Agent y probar más combinaciones
Nivel 5	Usuario + IP + User Agent, más un contador global	Combina el bloqueo por identidad del nivel 4 con un contador de fallos totales por usuario (30 en total). Esto permite identificar cuando se esta realizando un ataque de fuerza bruta que rota IP y User agent y contrarrestarlo.

Lo que evidenciamos en la práctica

- **Nivel 2 —** frena la fuerza bruta clásica, pero es demasiado agresivo: bloquea a la cuenta real sin importar quién la ataque, incluso si el dueño legítimo prueba desde otro lugar.

- **Niveles 3 y 4 —** afinan el criterio para no perjudicar al usuario legítimo, pero alcanza con que el atacante rote esos datos (algo trivial para un script) para seguir intentando sin límite. Lo demostramos con nuestro propio script de fuerza bruta, que cambia de IP y user agent cada 2 intentos y evade el bloqueo sin problema.
- **Nivel 5 —** suma un contador que no depende de la identidad, solo del total de fallos de esa cuenta. Así detecta un ataque distribuido (el mismo usuario atacado desde muchos orígenes distintos) y bloquea igual, aunque el atacante rote IP y user agent. El mismo script que evadía los niveles 3 y 4 fracasa acá.
- **Complejidad de contraseñas:** También cabe decir que una forma de que el usuario proteja de mejor manera su cuenta es crear una contraseña robusta, que incluya mayúsculas, minúsculas, números, símbolos y que sea de una longitud considerable. Si se hace de esta manera un script de fuerza bruta que vaya digito por digito le costara mucho mas trabajo encontrar la contraseña real porque las posibilidades son mucho mayores.
- **No repetir contraseñas:** Existen bancos de contraseñas comunes y de contraseñas filtradas. Si un usuario usa la misma contraseña en todas las cuentas, y una de esas bases de datos resulta comprometida esa contraseña puede llegar a un banco, haciendo que los scripts de fuerza bruta por diccionario tengan mas chances de entrar a la cuenta.

Conclusión

La seguridad frente a la fuerza bruta no es simplemente “tener un límite de intentos”, sino diseñar bien qué se cuenta y a qué nivel. Un criterio demasiado estricto (nivel 2) genera bloqueos injustos; uno demasiado específico (niveles 3 y 4) es evadible; un buen diseño combina ambos enfoques (nivel 5) para ser resistente sin sacrificar la experiencia del usuario legítimo.